



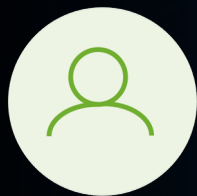
WEBINAR

ISO 27001:2022 & FRAMEWORK COMPLIANCE

Building an Effective and Measurable ISMS ISO/IEC 27001:2022



Kamis, 27 Agustus 2026



Narasumber: Haryatno

Principal Consultant, PT. Xynexis International

Table of Contents

Tujuan

1

5

Dari Compliance ke Resilience

Information Security vs Cybersecurity

2

6

Pendekatan Risiko dan GRC untuk Implementasi 27001:2022

Mengapa ISMS tidak efektif?

3

7

Compliance Architecture: Regulasi, ISO 27002, NIST CSF, COBIT

Kelemahan Pengukuran

4

8

Membangun dan Mengukur ISMS yang Efektif

Tujuan

**01**

Memahami konsep utama ISO 27001:2022 sebagai standar persyaratan ISMS

**02**

Memahami hubungan ISO 27001, ISO 27002, NIST CSF 2.0, dan regulasi

**03**

Menyusun pendekatan implementasi ISMS yang efektif berbasis risiko

**04**

Menentukan indikator pengukuran ISMS agar keamanan informasi dapat dipantau secara objektif

**05**

Memahami contoh pengukuran ISMS yang efektif

Information Security vs Cybersecurity

ISO/IEC 27001:2022

Information security, cybersecurity and privacy protection — Information security management systems — Requirements

Information Security

01

Definisi

Information security adalah upaya melindungi informasi baik dalam bentuk digital maupun non digital (fisik) untuk menjaga kerahasiaan, integritas, dan ketersediaannya.

02

Cakupan

- Data digital (database, email, sistem)
- Dokumen fisik (arsip, kontrak)
- Informasi lisan (rapat, percakapan)
- Proses dan manusia (people & process)

03

Fokus

- Perlindungan aset informasi
- Tata kelola, kebijakan, dan proses
- Risiko bisnis dan kepatuhan

04

Standar Rujukan

- ISO/IEC 27001 & 27002
- ISO/IEC 27005
- COBIT 2019

Cybersecurity

01

Definisi

Cybersecurity adalah upaya melindungi sistem, jaringan, aplikasi, dan data digital dari serangan siber yang berasal dari ruang siber.

02

Cakupan

- Jaringan dan infrastruktur TI
- Aplikasi dan sistem informasi
- Endpoint, server, cloud
- Ancaman siber (malware, hacking, phishing)

03

Fokus

- Pencegahan dan deteksi serangan siber
- Ketahanan sistem dan layanan digital
- Respon insiden siber

04

Standar Rujukan

- NIST Cybersecurity Framework
- NIST SP 800-series
- CIS Critical Security Controls

Mengapa ISMS tidak efektif?



Indikasi “Lack of Measurement”

Indikasi “Lack of Measurement” dalam ISMS adalah ketika organisasi sudah memiliki kebijakan, prosedur, dan kontrol, tetapi tidak dapat menunjukkan secara objektif apakah kontrol tersebut efektif dan apakah risiko benar-benar menurun.

Lack of Measurement

Indikasi	Contoh Kondisi Lack of Measurement
Tidak memiliki KPI/KRI keamanan informasi	Tidak ada metrik seperti patch compliance, phishing click rate, MTTR, atau jumlah vulnerability overdue
Target atau threshold tidak ditetapkan	Ada data insiden, tetapi tidak ada target seperti “MTTR < 4 jam”
Tidak ada baseline dan tren	Hanya mengetahui kondisi bulan ini tanpa membandingkan dengan periode sebelumnya
Metric tidak terhubung ke risk appetite	Manajemen tidak dapat mengetahui apakah exposure masih dapat diterima
Tidak ada SLA pengendalian risiko	Critical vulnerability tidak memiliki target waktu remediation
Tidak mengukur residual risk	Risk treatment dilakukan, tetapi tidak dievaluasi apakah level risiko menurun
Tidak mengukur control effectiveness	Backup dilakukan, tetapi tidak pernah diukur keberhasilan restore

KPI vs KRI

Aspek	KPI – Key Performance Indicator	KRI – Key Risk Indicator
Fokus	Kinerja proses/kontrol	Eksposur risiko
Pertanyaan utama	“Apakah kita bekerja sesuai target?”	“Apakah risiko kita meningkat?”
Sifat	Performance-oriented	Risk-oriented
Digunakan untuk	Mengukur pencapaian objective	Early warning terhadap peningkatan risiko
Contoh	% patch selesai sesuai SLA	Jumlah critical vulnerability yang telat diremediasi sesuai target (overdue)
Interpretasi	Semakin tinggi sering kali semakin baik	Semakin tinggi sering kali semakin berisiko
	Tidak mengukur control effectiveness	Backup dilakukan, tetapi tidak pernah diukur keberhasilan restore

Mengapa Pengukuran Efektivitas ISMS Sangat Penting?

Keamanan informasi tidak cukup hanya memiliki dokumen, kebijakan, dan checklist. Organisasi perlu memiliki sistem manajemen yang berjalan, terukur, dan terus diperbaiki.



1. Ancaman keamanan informasi semakin kompleks.
2. Regulasi dan tuntutan pelanggan semakin tinggi.
3. Sertifikasi bukan tujuan akhir, tetapi bukti kematangan tata kelola.
4. ISMS yang efektif harus berbasis risiko, terintegrasi dengan proses bisnis, dan memiliki indikator pengukuran

Dari Compliance Menuju Resilience

Compliance yang baik harus menghasilkan resilience, bukan hanya kelengkapan dokumen.

ISO 27001
INFORMATION
SECURITY

ISMS yang efektif harus berjalan, terukur, dan terus diperbaiki.

KELENGKAPAN DOKUMEN

Compliance berbasis dokumen saja



Statik, terfokus pada kelengkapan, bukan pada hasil.

DARI
COMPLIANCE
KE
RESILIENCE

Mengubah kepatuhan menjadi
ketangguhan yang melindungi
tujuan bisnis.

RESILIENCE

Compliance yang berjalan, terukur, dan berkelanjutan

- Risk-Based
Pendekatan berbasis risiko
- Control Effectiveness
Efektivitas kontrol
- Monitoring
Pemantauan berkelanjutan
- Incident Response
Tanggap dan pulih cepat
- Continual Improvement
Perbaikan berkelanjutan
- Measurable ISMS
ISMS terukur dan terbukti



ORGANISASI TANGGUH OPERASI STABIL ASET TERLINDUNG KEPERCAYAAN MENINGKAT KINERJA BISNIS BERKELANJUTAN

Hanya Compliance

- Fokus pada dokumen
- Lulus audit
- Reaktif

VS

Compliance yang Efektif

- Fokus pada efektivitas kontrol
- Risiko terkendali
- Proaktif dan terukur

KEAMANAN INFORMASI
TANGGUNG JAWAB KITA BERSAMA

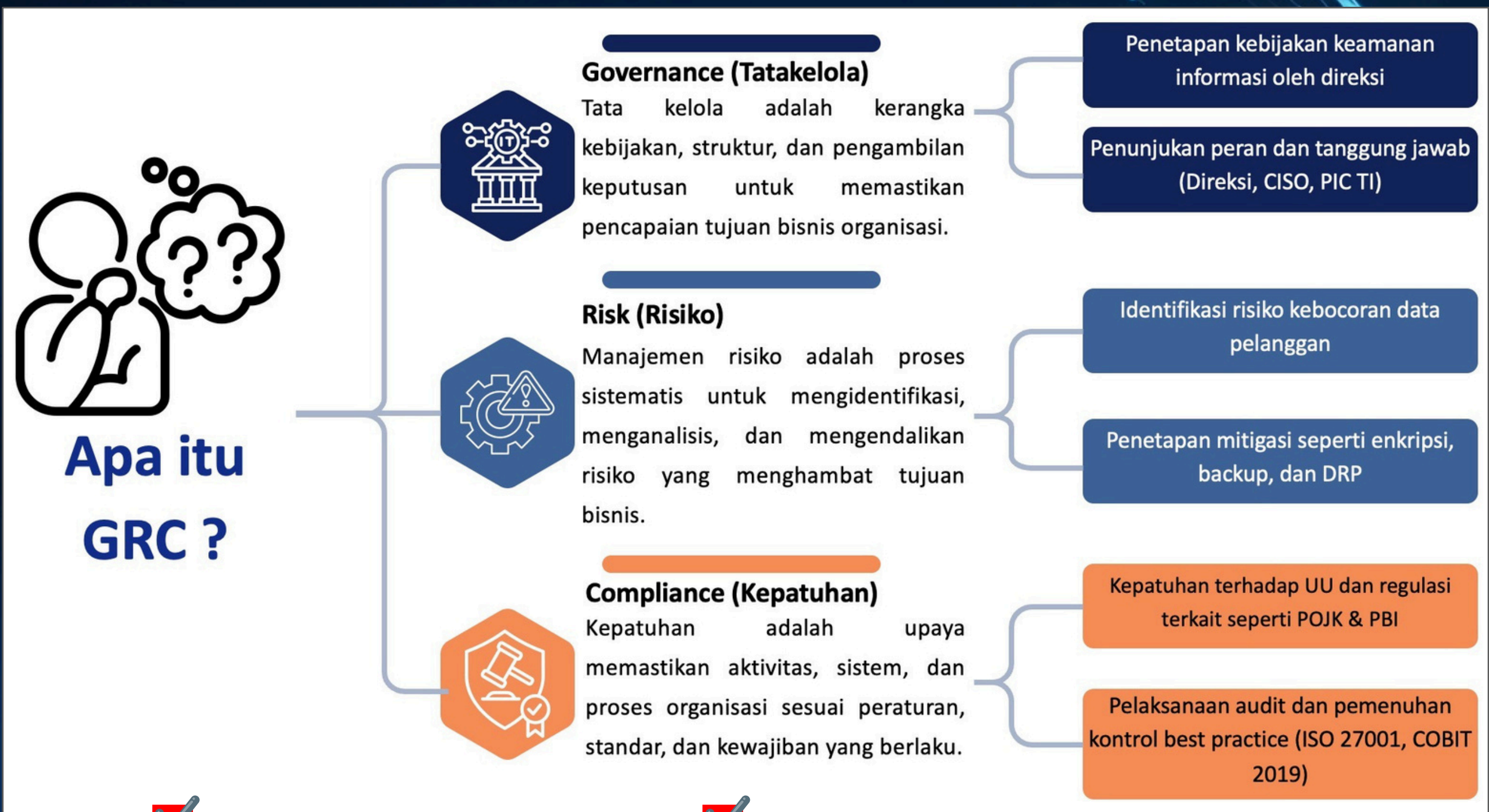
Secure Today. Resilient Tomorrow.

Esensi dan Komponen Utama ISMS

ISMS adalah sistem manajemen untuk mengelola keamanan informasi melalui kombinasi kebijakan, proses, struktur organisasi, pengelolaan risiko, kontrol, pengukuran, audit, dan perbaikan berkelanjutan.



Governance - Risk - Compliance (GRC)



Pendekatan Pengukuran Efektivitas ISMS dengan GRC

Pendekatan GRC mengubah ISMS menjadi risk-driven, measurable, dan dipantau secara berkelanjutan (**continuously monitored**).

Monitoring Review

(Continuous Improvement)
Dashboard bulanan / kuartal control monitoring (KPI & KRI, Incident & Lessons learned, Perbaikan Berkelanjutan)

Compliance

(Assure & Validate)
Petakan assessment ISMS dengan regulasi dan framework NIST CSF (1 control → multiple compliance requirements)

Governance

(Direction)
Tetapkan akuntabilitas & Peran & Tanggung Jawab yang jelas (Process Owner, Risk Owner, Control Owner, Security Owner)

Risk Management

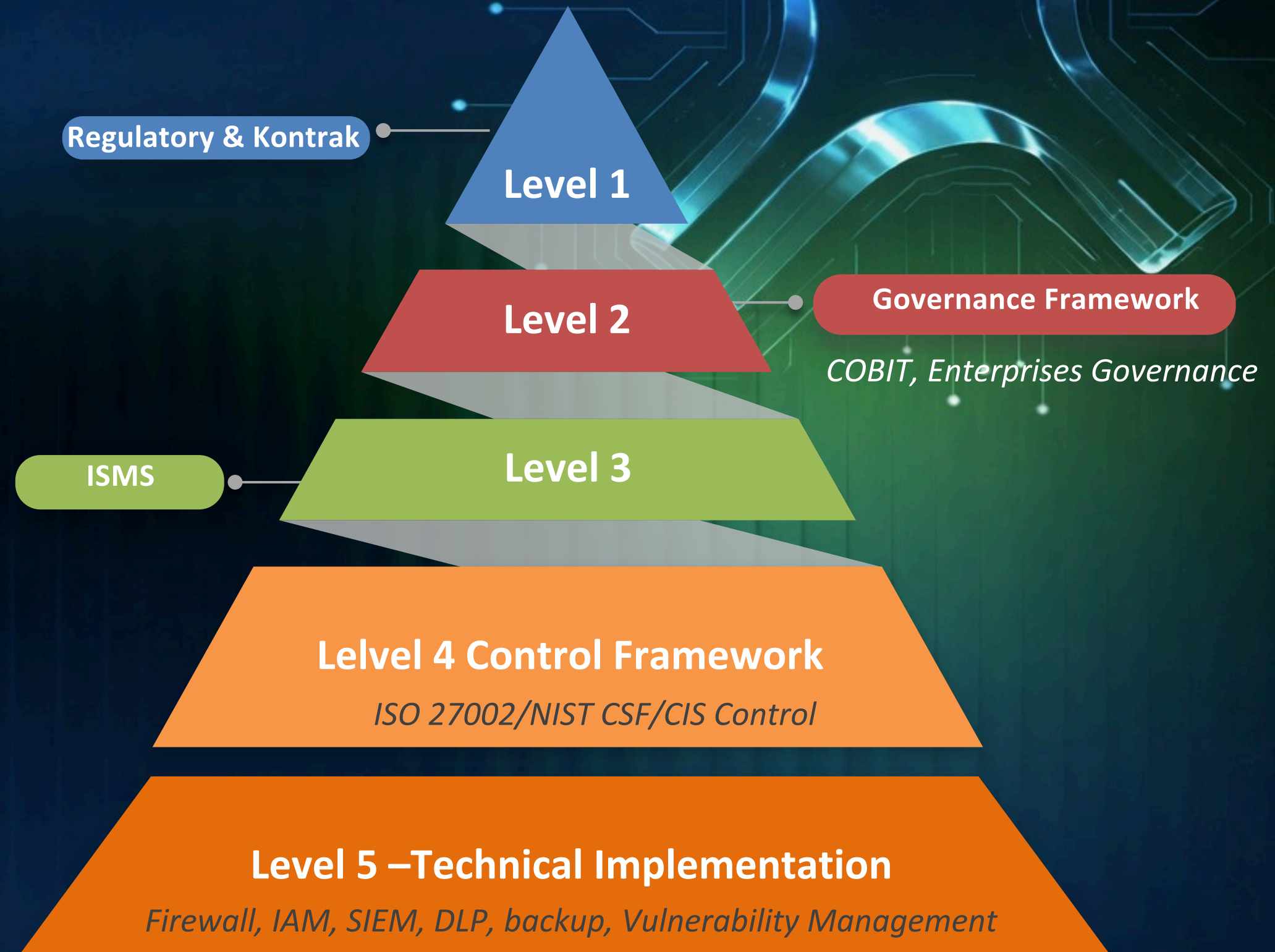
(Identify & Control)
Hubungkan setiap kontrol dengan risiko yang ditangani (Risiko credential compromise → MFA, PAM, access review)



Compliance Architecture: Integrasi dengan Standar lainnya

Untuk membangun dan menerapkan ISMS secara efektif, organisasi perlu mengintegrasikan beberapa framework:

- UU & Regulasi sektor (PDP, OJK, Bank Indonesia, BSSN).
- ISO/IEC 27002:2022 untuk panduan kontrol.
- NIST CSF 2.0 & CIS untuk outcome cybersecurity.*)
- COBIT untuk tata kelola TI.



*) [hMps://www.nist.gov/cyberframework](https://www.nist.gov/cyberframework)

*) CIS = Center for Internet Security ([hMps://www.cisecurity.org](https://www.cisecurity.org)).

Integrasi ISO 27002 dengan NIST CSF (cybersecurity Foundation)

Information security controls

Organizational Control
q37 Kontrol

People Control
q8 Kontrol

Physical Control
q14 Kontrol

Technical Control
q34 Kontrol

ATRIBUT CYBERSECURITY

Control Types

Kapan & bagaimana kontrol ini memodifikasi risiko terkait insiden:

- Preventive
- Detective
- Corrective

Cybersecurity Concepts:

Kemampuan kontrol mengelola dan mengoperasikan lingkungan yang aman:

1. **Govern,**
2. **Identify,**
3. **Protect,**
4. **Detect,**
5. **Respond,**
6. **Recover.**



Mapping ISO/IEC 27001:2022 vs NIST CSF 2.0

NIST CSF 2.0	Hubungan dengan ISMS
Govern (GV)	Leadership, policy, roles, risk appetite, compliance
Identify (ID)	Asset management, business context, risk assessment
Protect (PR)	Access control, awareness, data security, technology control
Detect (DE)	Logging, monitoring, anomaly detection
Respond (RS)	Incident response, communication, evidence handling
Recover (RC)	Backup, redundancy, BCP/DRP, lessons learned

ISO/IEC 27001:2022 dapat menjadi sistem manajemen utama, sedangkan NIST CSF 2.0 dapat digunakan sebagai framework untuk mengukur cakupan cybersecurity.

Contoh NIST CSF 2.0 vs ISO 27001:2022

NIST CSF 2.0

GOVERN (GV): The organization’s cybersecurity risk management strategy, expectations, and policy are established, communicated, and monitored	GV.OC-01: The organizational mission is understood and informs cybersecurity risk management	Ex1: Share the organization’s mission (e.g., through vision and mission statements, marketing, and service strategies) to provide a basis for identifying risks that may impede that mission
	GV.OC-02: Internal and external stakeholders are understood, and their needs and expectations regarding cybersecurity risk management are understood and considered	Ex1: Identify relevant internal stakeholders and their cybersecurity-related expectations (e.g., performance and risk expectations of officers, directors, and advisors; cultural expectations of employees) Ex2: Identify relevant external stakeholders and their cybersecurity-related expectations (e.g., privacy expectations of customers, business expectations of partnerships, compliance expectations of regulators, ethics expectations of society)

ISO 27001:2022

4 Context of the organization
4.1 Understanding the organization and its context
The organization shall determine external and internal issues that are relevant to its purpose and that affect its ability to achieve the intended outcome(s) of its information security management system. NOTE Determining these issues refers to establishing the external and internal context of the organization considered in Clause 5.4.1 of ISO 31000:2018^[5].
4.2 Understanding the needs and expectations of interested parties
The organization shall determine: a) interested parties that are relevant to the information security management system; b) the relevant requirements of these interested parties; c) which of these requirements will be addressed through the information security management system. NOTE The requirements of interested parties can include legal and regulatory requirements and contractual obligations.

Prinsip Dasar Keamanan Informasi & Kontrol

PRINSIP

Confiden'ality (Kerahasiaan)

informasi hanya dapat diakses oleh pihak yang berwenang.

Integrity (Integritas)

informasi harus tetap akurat, lengkap, dan tidak boleh diubah secara tidak sah.

Availability (Ketersediaan)

informasi dan sistem harus tersedia ketika dibutuhkan oleh pengguna yang sah.

Accountability (Akuntabilitas)

setiap aktivitas dalam sistem dapat ditelusuri ke pengguna yang melakukan tindakan tersebut.

Non-Repudiation (Tidak dapat menyangkal)

seseorang tidak dapat menyangkal bahwa ia telah melakukan suatu tindakan atau transaksi.

RISIKO

- Data pelanggan bocor;
- Database diakses tanpa izin,
- Credential admin dicuri

- Data transaksi dimanipulasi,
- Database corruption,
- Malware mengubah file

- Server down
- DDoS attack
- Kegagalan hardware

- Aktivitas user tidak tercatat
- Admin abuse privilege
- Audit trail tidak ada

- Transaksi tidak dapat dibuktikan;
- User menyangkal aktivitas;
- Tidak ada bukti digital

KONTROL

- Access Control,
- Encryption,
- Data classification,
- Identity management

- Hashing
- Digital signature
- Change management
- Logging

- Backup
- Disaster recovery
- Redundancy
- Monitoring

- Audit logging
- Privileged access management
- Monitoring
- Identity management

- Digital signature
- Secure logging
- Timestamping
- Cryptographic proof

STANDAR

(ISO 27001 & NIST CSF 2.0)

ISO 27001:

5.15 Access Control, 5.16 Identity Management, 5.12 Information Classification

CSF 2.0:

PR.AA (Identity Management), PR.AC Access Control, PR.DS (Data Security)

ISO 27001:

8.32 Change Management; 8.15 Logging; 8.24 Cryptography

CSF 2.0:

PR.IP System Integrity; DE.CM Monitoring; PR.DS Data Integrity; GV.RM Risk Management

ISO 27001:

8.13 Backup; 5.30 Business Continuity; 8.14 Redundancy; 8.16 Monitoring

CSF 2.0:

PR.IR Infrastructure Resilience; RC Recovery; PR.PS Platform Security; DE.CM Continuous Monitoring

ISO 27001:

8.15 Logging; 8.16 Monitoring; 5.18 Access Rights

CSF 2.0:

DE.CM Monitoring; DE.AE Anomaly Detection; PR.AA Identity Management

ISO 27001:

8.24 Cryptography; 8.15 Logging; 5.28 Evidence Collection

CSF 2.0:

PR.DS Data Security; DE.CM Monitoring; RS.AN Incident Analysis

Membangun dan Mengukur ISMS Yang Efektif



1. Tetapkan Sasaran Keamanan (Security Objectives)

Mulai dari apa yang ingin dicapai ISMS.

Contoh:

- **Objective:** Mengurangi risiko eksploitasi vulnerability pada critical systems.

Objective harus:

- Spesifik;
- Measurable;
- Relevan terhadap business risk;
- Memiliki target;
- Memiliki owner.

Contoh target:

- Critical vulnerabilities remediated within SLA $\geq 95\%$.

2. Hubungkan Sasaran dengan

- **Identifikasi risiko yang mengancam tercapainya objective.** Contoh:
- **Risk:** Eksploitasi dari kelemahan kritikal yang tidak dipatch.
- **Impact:**
 - Unauthorized access;
 - Data breach;
 - System compromise;
 - Service disruption.
- Measurement bukan sekadar mengukur aktivitas, tetapi mengukur **risiko yang ingin dikendalikan.**

Risiko yang perlu mendapatkan prioritas

Prioritas Risiko 2026	Kontrol ISO/IEC 27001:2022 / 27002:2022 yang Diprioritaskan	Mengapa Prioritas
1. Identity & Credential Compromise	5.15 Access Control; 5.16 Identity Management; 5.17 Authentication Information; 5.18 Access Rights; 8.2 Privileged Access Rights; 8.3 Information Access Restriction; 8.5 Secure Authentication	Credential theft, infostealer, phishing dan penyalahgunaan privileged account tetap menjadi jalur serangan utama
2. Vulnerability Exploitation	8.8 Management of Technical Vulnerabilities; 8.9 Configuration Management; 8.19 Installation of Software; 8.20 Network Security	Public-facing application dan vulnerability yang belum dipatch menjadi attack surface kritis
3. Ransomware & Malware	8.7 Protection Against Malware; 8.13 Information Backup; 8.14 Redundancy; 8.15 Logging; 8.16 Monitoring Activities	Pencegahan saja tidak cukup; organisasi perlu kemampuan detection dan recovery
4. Detection & Incident Response	5.7 Threat Intelligence; 5.24–5.28 Incident Management; 8.15 Logging; 8.16 Monitoring Activities	Attack speed meningkat sehingga kemampuan mendeteksi, menganalisis, dan merespons menjadi kritis
5. Third-Party / Supply Chain Risk	5.19 Supplier Relationships; 5.20 Supplier Agreements; 5.21 ICT Supply Chain; 5.22 Monitoring Supplier Services; 5.23 Cloud Services	Kompromi supplier/SaaS/software supply chain dapat memberikan attacker jalur masuk melalui trusted relationship
6. Application & Software Supply-Chain Security	8.25 Secure Development Life Cycle; 8.26 Application Security Requirements; 8.27 Secure Architecture; 8.28 Secure Coding; 8.29 Security Testing; 8.30 Outsourced Development; 8.32 Change Management	Attack terhadap aplikasi, API, dependency, CI/CD dan developer identity semakin relevan
7. Data Leakage & AI-Related Data Exposure	5.12 Classification; 5.14 Information Transfer; 8.11 Data Masking; 8.12 Data Leakage Prevention; 8.24 Cryptography	Penggunaan cloud dan GenAI meningkatkan kemungkinan sensitive data masuk ke platform yang tidak dikendalikan
8. Cloud & Configuration Risk	5.23 Cloud Services; 8.9 Configuration Management; 8.20 Network Security; 8.21 Security of Network Services; 8.22 Segregation of Networks	Misconfiguration dan kompleksitas cloud memperbesar attack surface
9. Social Engineering & Cyber Fraud	6.3 Information Security Awareness; 6.8 Information Security Event Reporting; 5.17 Authentication Information; 8.5 Secure Authentication	AI semakin memudahkan phishing, impersonation dan fraud yang lebih meyakinkan
10. Cyber Resilience	5.29 Information Security During Disruption; 5.30 ICT Readiness for Business Continuity; 8.13 Backup; 8.14 Redundancy	Fokus security bergeser dari hanya “prevent breach” menjadi “survive and recover from breach”

3. Tentukan Key Controls

- Prioritaskan **key controls** berdasarkan:
 - Critical risk;
 - Regulatory requirement; critical asset;
 - Historical incidents;
 - Threat landscape;
 - Management concern.
- Contoh untuk vulnerability risk:
 - A.8.8 Management of Technical Vulnerabilities;
 - A.8.9 Configuration Management;
 - A.8.16 Monitoring Activities.

Contoh KPI & KRI Kontrol Prioritas ISO/IEC 27002:2022

Kontrol ISO 27002:2022	Contoh KPI	Target KPI	Contoh KRI	Threshold KRI
Threat Intelligence	% threat intelligence relevan yang dianalisis dan ditindaklanjuti sesuai SLA	≥95%	Jumlah critical threat yang tidak ditindaklanjuti sesuai SLA	≤2
Access Control	% sistem kritis yang menerapkan access control sesuai policy	100%	Jumlah unauthorized access yang terkonfirmasi	0 critical
Identity Management	% user provisioning/deprovisioning selesai sesuai SLA	≥98%	Jumlah akun pegawai terminated yang masih aktif melewati SLA	0
Authentication Information	% akun yang memenuhi password/authentication standard	≥98%	Jumlah credential compromise yang terkonfirmasi	≤ threshold organisasi
Access Rights	% periodic access review selesai tepat waktu	≥95%	Jumlah akses tidak sesuai kebutuhan bisnis yang belum dicabut	≤2 critical
ICT Supply Chain	% critical supplier yang telah menjalani security assessment	100%	Jumlah critical supplier dengan unresolved High/Critical risk	0–2
Supplier Service Monitoring	% critical supplier yang direview sesuai jadwal	100%	Jumlah supplier critical dengan SLA/security breach berulang	≤2
Cloud Services	% cloud service yang telah melalui security assessment	100%	Jumlah critical cloud misconfiguration yang belum diremediasi	0
Incident Management	% incident ditangani sesuai incident-response SLA	≥95%	Jumlah High/Critical incident yang melewati response SLA	≤2
Information Security During Disruption	% critical process memiliki security controls selama disruption	100%	Jumlah critical security control yang tidak tersedia selama disruption	0
ICT Readiness for Business Continuity	% critical system berhasil memenuhi RTO/RPO pada DR test	100%	Jumlah critical system yang gagal mencapai RTO/RPO	0
Awareness, Education and Training	% pegawai menyelesaikan awareness sesuai jadwal	≥95%	Phishing simulation click rate	<5%

Contoh Metrik ISMS

Area	Metric	Formula / Pengukuran	Target	Evidence
Risk Management	Penyelesaian risk treatment	Jumlah action selesai / total action	$\geq 90\%$ tepat waktu	Risk treatment tracker
Access Control	Review hak akses	Jumlah review selesai / total sistem kritikal	100% per periode	Berita acara review
Vulnerability	SLA patch critical	Critical vulnerability ditutup sesuai SLA	$\geq 95\%$	VA report, patch record
Incident	MTTR insiden	Rata-rata waktu pemulihan insiden	Sesuai target internal	Incident report
Monitoring	Log coverage	Sistem kritikal yang mengirim log ke SIEM	100% sistem kritikal	SIEM source list
Awareness	Completion rate training	Peserta selesai training / total peserta wajib	$\geq 95\%$	LMS report
Supplier	Assessment vendor kritikal	Vendor kritikal yang dinilai	100% per tahun	Supplier assessment
Backup	Restore test success	Pengujian restore berhasil / total pengujian	100%	DR/restore test report
Audit	Closure temuan	Temuan ditutup sesuai target	$\geq 90\%$	CAPA tracker

5. Tentukan Target dan Threshold

- Setiap indikator harus punya threshold/batas.

Hasil	Status
0—2	 Acceptable
3—5	 Attention
>5	 Escalation

- Contoh:
 - Critical vulnerability overdue

Tanpa threshold, angka: “Ada 7 vulnerability overdue” tidak memberi informasi kepada manajemen apakah angka tersebut **acceptable** atau **unacceptable**.

6. Tentukan Sumber Data dan Frekuensi

ISO 27001 klausul 9.1 Monitoring, measurement, analysis and evaluation:
mengharuskan organisasi menentukan **apa yang dimonitor, metode, kapan dilakukan, dan siapa yang melakukan.**

Metric	Data Source	Frequency	Owner
Patch Compliance	Vulnerability Management Tool	Monthly	Infrastructure
MFA Coverage	IAM	Monthly	IAM Team
Phishing Click Rate	Awareness Platform	Quarterly	InfoSec
Backup Success	Backup System	Daily/Monthly reporting	IT Operations
MTTR Incident	SIEM / Incident Ticket	Monthly	SOC

7. Ukur Control Effectiveness

A. Design Effectiveness

- Apakah desain kontrol memadai untuk menangani risiko?
- Contoh: MFA diwajibkan untuk privileged users.

B. Implementation Effectiveness

- Apakah kontrol sudah diterapkan sesuai desain?
- Contoh: 100% privileged users sudah enrolled MFA.

C. Operating Effectiveness

- Apakah kontrol berjalan secara konsisten?
- Contoh: Tidak ditemukan bypass MFA dalam sampling 3 bulan.

D. Risk Effectiveness

- Apakah kontrol benar-benar menurunkan risiko?
- Contoh: Credential-related privileged account incidents turun dari 8 menjadi 1.

8. Evaluasi Residual Risk

Setelah kontrol diukur, tanyakan:

- **Apakah residual risk sekarang berada dalam risk appetite?**

Contoh:

- Sebelum kontrol:
 - **Risk = Extreme**
- Setelah penerapan MFA + PAM + monitoring:
 - **Residual Risk = Medium**
- Risk appetite organisasi: **Medium**

Kesimpulan:

- **Residual risk acceptable.**
- Jika masih High atau Extreme: diperlukan treatment tambahan

9. Analisis Trend

- Misalnya phishing click rate:

Periode	Click Rate
Q1	14%
Q2	10%
Q3	7%
Q4	4%

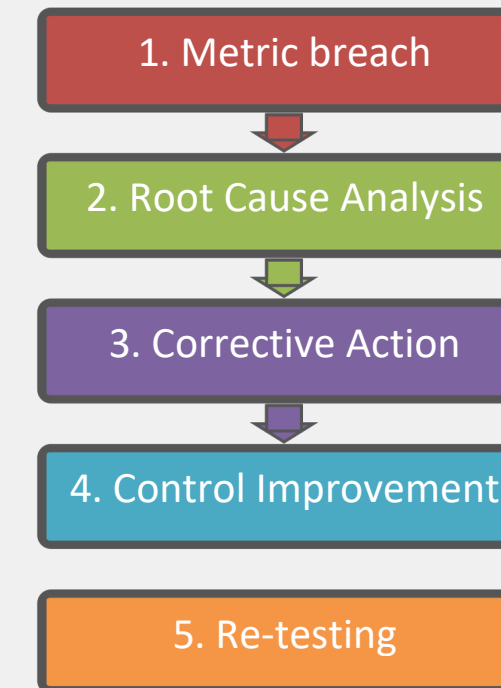
- Meskipun Q1 tinggi, tren menunjukkan:
 - **Efektivitas kontrol meningkat.**
- Trend analysis membuat ISMS jauh lebih meaningful daripada snapshot audit.

10. Management Review

- Hasil measurement harus menjadi bahan **management decision-making**.
- Management dashboard sebaiknya menunjukkan:
 - Top risks;
 - Residual risks di atas appetite; KPI below target;
 - KRI above threshold; ineffective controls;
 - Overdue corrective actions; significant incidents;
 - Audit findings;
 - Improvement trend.
- Bahan Management untuk memutuskan:
 - ☐ Accept ☐ Treat ☐ Allocate Resources ☐ Lainnya

11. Corrective Action

- Jika kontrol tidak efektif, lakukan langkah 1-5 seperti gambar di bawah:



- Contoh:
 - **KRI:** Critical vulnerability overdue = 12
 - Threshold = 5.
 - Root cause: Patch approval process terlalu lama.
 - Corrective action: Emergency patch process untuk CVSS critical / actively exploited vulnerability.

12. Re-measure dan Continual Improvement

- Setelah corrective action diterapkan, ukur kembali.
- Misalnya:
- **Sebelum improvement**
 - Critical vulnerability overdue = 12
- **Setelah 3 bulan**
 - Critical vulnerability overdue = 3
- Kesimpulan: terdapat evidence bahwa **treatment memperbaiki control effectiveness.**

Mini Case Study

Konteks:

Sebuah perusahaan penyedia layanan digital memiliki aplikasi pelanggan, database pelanggan, cloud infrastructure, tim operasional TI, dan beberapa vendor pendukung.

Masalah yang ditemukan:

- Belum ada risk register yang konsisten.
- Review hak akses belum berkala.
- Log aplikasi belum seluruhnya masuk SIEM.
- Vendor kritisal belum dinilai dari aspek keamanan.
- Backup dilakukan, tetapi restore test belum terdokumentasi.

Bahan Diskusi peserta (jika dimungkinkan):

Tentukan 3 risiko utama, kontrol yang relevan, dan metrik pengukurannya.

Contoh Jawaban Case Study

Contoh pendekatan pengukuran efektivitas kontrol:

Risiko	Kontrol	Metrik
Akses tidak sah ke aplikasi pelanggan	Access review, MFA, privileged access management	100% akun privileged direview per kuartal
Aktivitas anomali tidak terdeteksi	Centralized logging, SIEM, monitoring alert	100% sistem kritis mengirim log ke SIEM
Gangguan layanan tidak dapat dipulihkan	Backup, restore test, DRP	100% restore test berhasil sesuai RTO/RPO
Risiko keamanan dari vendor	Supplier security assessment	100% vendor kritis dinilai sebelum onboarding
Kelemahan teknis tidak ditangani	Vulnerability management dan patch SLA	$\leq 95\%$ critical vulnerability ditutup sesuai SLA

Rangkuman Poin Penting ISMS Yang Efektif

1. ISO/IEC 27001:2022 adalah sistem manajemen, bukan sekadar sistem dokumentasi.
2. ISMS yang efektif harus berbasis risiko dan relevan dengan bisnis.
3. Framework lain seperti NIST CSF 2.0 dapat digunakan untuk memperkuat struktur outcome dan pengukuran cybersecurity.
4. Compliance yang baik harus menghasilkan kontrol yang berjalan.
5. ISMS harus dapat diukur melalui KPI, KRI, evidence, audit, dan continual improvement.
6. Tujuan akhir ISMS adalah menjaga confidentiality, integrity, availability, dan kepercayaan stakeholder

Selesai & Terima Kasih